

Министерство образования Республики Беларусь

Учреждение образования
**БЕЛОРУССКИЙ ГОСУДАРСТВЕННЫЙ УНИВЕРСИТЕТ
ИНФОРМАТИКИ И РАДИОЭЛЕКТРОНИКИ**

Факультет информационных технологий и управления
Кафедра интеллектуальных информационных технологий

ОТЧЕТ
по лабораторной работе №4
по дисциплине «Проектирование защищённых интеллектуальных
информационных систем»
на тему:

Безопасность работы удалённых серверов в сети Internet.

Часть 1. Анализ запросов из сети Internet.

**Часть 2. Усовершенствование системы безопасности удалённых
серверов**

Студенты гр. 321701

Руководитель

И. А. Политыко

В. А. Лукашов

Д. А. Сальников

Минск 2026

СОДЕРЖАНИЕ

Перечень условных обозначений	3
1 Постановка задачи	4
2 Часть 1. Анализ запросов из сети Internet	5
3 Часть 2. Усовершенствование системы безопасности удалённых серверов	9
Заключение	12
Список использованных источников	13

ПЕРЕЧЕНЬ УСЛОВНЫХ ОБОЗНАЧЕНИЙ

SSH	— Secure Shell, Защищённый удалённый доступ;
HTTP	— Hypertext Transfer Protocol;
IDS	— Intrusion Detection System, Обнаружение вторжений;
IPS	— Intrusion Prevention System, Предотвращение вторжений;
NIDS	— Network IDS, Сетевое обнаружение вторжений;
HIDS	— Host IDS, Хостовое обнаружение вторжений;
SID	— Signature Identifier, Идентификатор сигнатуры Snort;
ACL	— Access Control List, Список контроля доступа;
VPN	— Virtual Private Network, Виртуальная частная сеть;
pcap	— Packet capture, Формат записи сетевых кадров.

1 ПОСТАНОВКА ЗАДАЧИ

Целью работы является исследование запросов из сети Internet к удалённому узлу и усовершенствование его защиты средствами обнаружения вторжений.

В части 1 необходимо разместить на узле веб-сервер с тестовой страницей, настроить журналирование, выполнить анализ журналов SSH и веб-сервера за несколько дней и сформулировать рекомендации.

В части 2 необходимо установить и настроить средство защиты по варианту (Snort), повторно проанализировать журналы подсистем, сравнить картину до и после настройки политики и сформулировать выводы.

2 ЧАСТЬ 1. АНАЛИЗ ЗАПРОСОВ ИЗ СЕТИ INTERNET

Краткое описание веб-сервера. На учебном узле развёрнут HTTP-сервер на языке Python. Он отдаёт тестовую страницу «Сводка»: состояние служб, ссылки на машинное описание и `robots.txt`. Журнал доступа ведётся в формате Combined (адрес, время, строка запроса, код, размер, Referer, User-Agent). Журнал ошибок фиксирует ответы с кодом 4xx. Параллельно работает учебный SSH-endpoint на библиотеке Paramiko: принимается только открытый ключ оператора, интерактивная оболочка не выдаётся, слушается нестандартный порт, чтобы снизить долю сканеров, нацеленных на порт 22. Это не штатный `sshd` операционной системы, а стенд журналирования попыток входа. Схема узла показана на рисунке 2.1. Внешний вид страницы — на рисунке 2.2.

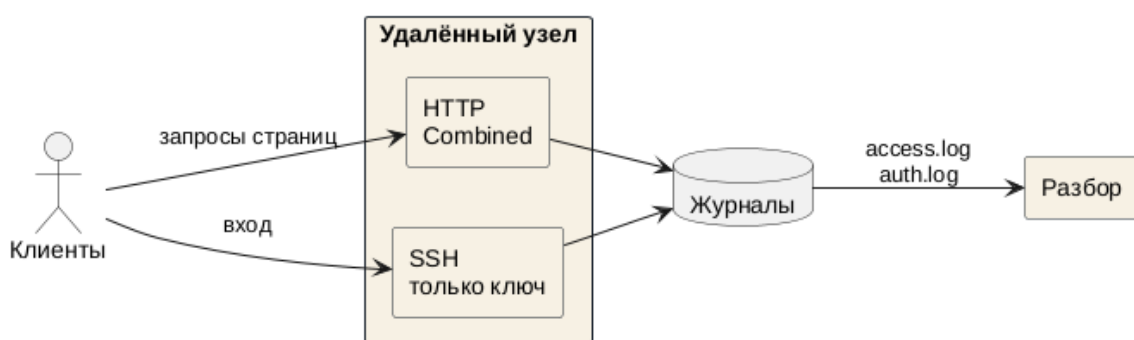


Рисунок 2.1 — Поток запросов и журналы учебного узла

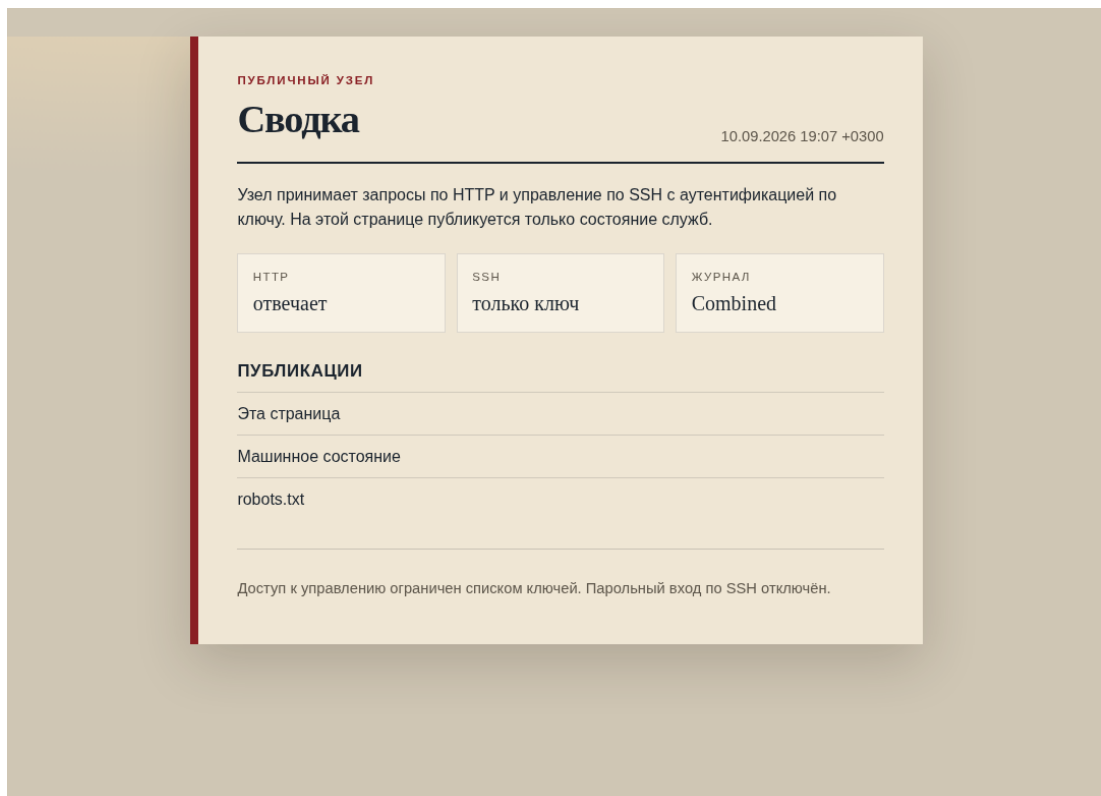


Рисунок 2.2— Тестовая страница, доступная по HTTP

Анализируемые файлы. Для разбора использованы три журнала. `access.log`— Combined веб-сервера: по строке восстанавливаются источник, путь, код ответа и клиентская программа. `error.log`— пояснения к отказам (нет такого пути, отклонённый обход каталога). `auth.log`— журнал SSH в формате syslog: успешный вход по ключу, отказ пароля, несуществующая учётная запись, обрыв после серии неудач, отсутствие идентификационной строки. Фрагменты приведены в листингах 2.1 и 2.2.

Недельный ряд (04.09.2026–10.09.2026) сформирован генератором типового шума: внешние адреса взяты из документационных диапазонов RFC 5737, чтобы воспроизводимо показать классы разведки из Internet, не смешивая их с адресами живого канала. Это учебная модель журналов, а не выгрузка с публичного VPS. Живой endpoint при демонстрации пишет в те же файлы уже фактические обращения к локальному стенду.

```

1 198.51.100.12 - - [04/Sep/2026:06:50:00 +0300] "GET /wp-login.php HTTP/1.1" 404 412 "-"
   "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
   Chrome/124.0.0.0 Safari/537.36"
2 198.51.100.12 - - [04/Sep/2026:06:50:03 +0300] "GET /wp-admin/ HTTP/1.1" 404 412 "-"
   "Mozilla/5.0 (compatible; zgrab/0.1)"
3 198.51.100.12 - - [04/Sep/2026:06:50:06 +0300] "GET /xmlrpc.php HTTP/1.1" 404 412 "-"
   "Mozilla/5.0 (compatible; Nmap Scripting Engine)"
4 198.51.100.12 - - [04/Sep/2026:06:50:09 +0300] "GET /phpmyadmin/ HTTP/1.1" 404 412 "-"
   "sqlmap/1.8.2#stable (http://sqlmap.org)"

```

Листинг 2.1— Фрагмент Combined-журнала веб-сервера

```

1 Sep  4 03:10:00 node sshd[18002]: Failed password for root from 203.0.113.40 port 51000
  ssh2
2 Sep  4 05:01:01 node sshd[18029]: Invalid user admin from 203.0.113.55 port 43000
3 Sep  4 09:05:18 node sshd[18001]: Accepted publickey for operator from 10.206.216.10
  port 48571 ssh2: RSA SHA256:lab4operator

```

Листинг 2.2 — Фрагмент журнала SSH

Анализ запросов. За семь суток веб-сервер зафиксировал 200 обращений, служба SSH — 387 событий. По HTTP коды распределились так: 95 ответов 200, 91 ответ 404, 14 ответов 400. Классификация путей и заголовков User-Agent приведена в таблице 2.1. Легитимный трафик (сводка, состояние, `robots.txt`, проверка доступности) составляет 74 записи и исходит с адресов локальной сети. Остальное — разведка: сканеры CMS (WordPress, phpMyAdmin), поиск файлов секретов (`.env`, `.git/config`), обход пути к `/etc/passwd`, шаблоны инъекции в URI, а также явные сканеры в User-Agent (sqlmap, Hydra, Nmap, masscan, zgrab). Лидирующий внешний источник HTTP — 198.51.100.12 (98 запросов).

Класс	Записей
легитимный	74
сканер CMS	56
утечка секретов	28
инъекция в URI	21
обход пути	14
сканер по User-Agent	7

Таблица 2.1 — Классификация записей Combined-журнала

По SSH успешных входов по ключу ровно семь — по одному в рабочие часы каждого дня с адреса оператора 10.206.216.10. Неверный пароль зафиксирован 206 раз, обращения к несуществующим учётным записям — 119, принудительные отключения после серии неудач — 30, отсутствие баннера — 4. Ночной перебор root идёт с 203.0.113.40 (229 событий). Словарь имён (`admin`, `ubuntu`, `postgres`, `oracle` и др.) — с 203.0.113.55. Адрес 192.0.2.88 появляется сразу в двух подсистемах: неудачный SSH и запросы `/.env` и `wp-login.php`. Такая корреляция важнее одиночного 404: один источник ведёт разведку и по оболочке, и по веб-корню. В учебном endpoint парольный метод не предлагается; строки `Failed password` в недельном ряду — модель того, как выглядит перебор в типичном `auth.log`, а не дамп живого `sshd` с `PasswordAuthentication` по.

По суткам нагрузка стабильна (таблица 2.2): веб — 25–32 записи в день, SSH — 47–60. Такой ровный фон типичен для узла, который виден из

Internet; в стенде он воспроизведён генератором, чтобы разбор не зависел от случайной недели канала.

Дата	HTTP	SSH
04.09.2026	29	54
05.09.2026	26	59
06.09.2026	30	60
07.09.2026	25	57
08.09.2026	32	55
09.09.2026	29	55
10.09.2026	29	47

Таблица 2.2— Число записей журналов по суткам

Рекомендации. По журналам без IDS уже видно, что делать. Для SSH: оставить только ключи, запретить вход `root` и парольную аутентификацию, ограничить источники (`AllowUsers` и ACL межсетевого экрана), при необходимости вынести управление в VPN. Для HTTP: не публиковать панели CMS и phpMyAdmin, отдавать 404 без различия путей, не держать `.env` в корне. Для реакции: порог по числу отказов с одного адреса и сетевая IDS, которая разбирает не только syslog, но и содержимое HTTP. Это переход ко второй части работы.

3 ЧАСТЬ 2. УСОВЕРШЕНСТВОВАНИЕ СИСТЕМЫ БЕЗОПАСНОСТИ УДАЛЁННЫХ СЕРВЕРОВ

Описание установленного программного обеспечения. По варианту установлена система Snort версии 2.9.15.1. Это сетевая IDS (NIDS): она читает кадры с интерфейса или из файла `pcap`, применяет набор сигнатур и формирует журнал событий. В документации выделены три режима: `sniffer` (вывод пакетов на консоль), `packet sniffer` и режим обнаружения. Режим `IPS (inline)` для Snort означает уже не только запись события, но и сброс или отклонение потока; на учебном узле выбран режим обнаружения, а реакция вынесена в список блокировки. Принцип работы: информационный источник — кадры Ethernet/IP/TCP; анализ — правила с идентификаторами `SID`; ответ — запись в `alert` и перечень адресов вне `HOME_NET`. Конвейер показан на рисунке 3.1.



Рисунок 3.1 — Конвейер Snort: трафик, сигнатуры, список блокировки

Локальный набор правил рассчитан на наблюдаемые в части 1 классы: `phpMyAdmin`, `WordPress`, обход пути, `.env`, `User-Agent sqlmap` и `Hydra`, `SYN` на порт `SSH`, шаблон инъекции `OR+` в `URI`. Фрагмент правил — в листинге 3.1.

```
1 alert tcp any any -> any 8088 (msg:"WEB phpMyAdmin probe"; content:"phpmyadmin"; nocase;  
  sid:1000001; classtype:web-application-activity;)  
2 alert tcp any any -> any 8088 (msg:"WEB path traversal"; content:"../"; sid:1000002;  
  classtype:web-application-attack;)  
3 alert tcp any any -> any 8088 (msg:"WEB sqlmap scanner"; content:"sqlmap"; nocase;  
  sid:1000005; classtype:web-application-attack;)  
4 alert tcp any any -> any 2222 (msg:"SSH SYN probe"; flags:S; sid:1000007;  
  classtype:attempted-recon;)
```

Листинг 3.1 — Локальные сигнатуры Snort

Анализируемые подсистемы и файлы. Подсистемы те же, что в части 1: `HTTP` и `SSH`. К журналам `Combined` и `syslog` добавляются `snort.conf` (домашняя сеть, классификация, подключение правил), файл сигнатур, `pcap` с характерными кадрами и `alert` — журнал срабатываний. Каждая строка `alert` содержит `SID`, текст, класс, приоритет и пару адресов. По `alert` строится `blocklist`: адреса, которые не входят в `HOME_NET`. Легитимный запрос оператора с `10.206.216.10` в список не попадает.

Анализ до и после настройки. До включения Snort единственным источником сведений оставались `access.log` и `auth.log`. По ним видно пе-

ребор и сканирование, но нет автоматического сопоставления содержимого HTTP с атакой и нет готового списка для ACL. После прогона в режиме IDS по девяти учебным кадрам рсар, отражающим те же классы, что и недельный журнал, получено 11 срабатываний (листинг 3.2). Все восемь локальных сигнатур отработали на соответствующих кадрах; легитимный GET оператора предупреждений не дал. Прогон выполнен чтением файла, а не на живом интерфейсе: так воспроизводится реакция на те же классы без зеркалирования канала.

```

1 [1:1000003:1] WEB WordPress login probe {TCP} 198.51.100.12 -> 10.206.216.245:8088
2 [1:1000002:1] WEB path traversal {TCP} 198.51.100.77 -> 10.206.216.245:8088
3 [1:1000008:1] WEB SQLi pattern {TCP} 198.51.100.77 -> 10.206.216.245:8088
4 [1:1000007:1] SSH SYN probe {TCP} 203.0.113.40 -> 10.206.216.245:2222

```

Листинг 3.2— Фрагмент журнала alert Snort

Сводка сравнения — таблица 3.1. После настройки в `blocklist` входят 192.0.2.88, 198.51.100.12, 198.51.100.77, 203.0.113.40. Эти адреса совпадают с лидерами шума в части 1, включая коррелированный 192.0.2.88. Практически список можно подать в межсетевой экран или fail2ban; это уже шаг к IPS, хотя сам Snort в данном прогоне пакеты не отбрасывал.

Показатель	До	После
Источник сведений	только Combined и syslog	журналы плюс alert
Автоматическая классификация HTTP	нет	8 сигнатур
Срабатываний IDS	0	11
Адресов в списке блокировки	0	4
Ложные срабатывания на оператора	нет	0

Таблица 3.1— Запросы и реакция до и после включения Snort

Сравнение с аналогами. Snort — классическая сигнатурная NIDS. Suricata решает тот же класс задач, но рассчитана на многопоточный разбор и удобнее как IPS на границе. OSSEC (Wazuh) — хостовая IDS: она смотрит журналы и целостность файлов, а не полезную нагрузку HTTP в кадре. Tripwire — контроль целостности файловой системы, а не сетевой поток. Bro/Zeek ближе к сетевому анализу сессий, чем к готовому набору SID. Для данной работы выбран Snort: он прямо сопоставляет содержимое запросов из Internet с правилами и даёт воспроизводимый **alert** без перевода узла в inline.

Средство	Класс	Сильная сторона
Snort	NIDS / IPS	сигнатуры HTTP и портов
Suricata	NIDS / IPS	многопоточность, рубеж сети
OSSEC	HIDS	журналы и целостность хоста
Tripwire	FIM	контроль файлов, не трафик
Bro / Zeek	NIDS (сессии)	разбор потоков, не готовые SID

Таблица 3.2 — Сопоставление средств из перечня вариантов

ЗАКЛЮЧЕНИЕ

В лабораторной работе на учебном стенде размещены веб-сервер с тестовой страницей и SSH-endpoint, настроено журналирование Combined и syslog, разобран недельный ряд типового шума (RFC 5737) и подключена сетевая IDS Snort с локальными сигнатурами и списком блокировки.

Семантическая составляющая. Безопасность удалённого сервера в сети Internet определяется не фактом наличия SSH и HTTP, а тем, какие попытки доступа попадают в журнал и как они читаются. Перебор пароля `root`, словарь несуществующих имён, сканирование CMS и поиск `.env` — это не сбой узла, а ожидаемый фон. Корреляция одного адреса сразу в SSH и HTTP важнее изолированного кода 404. IDS не заменяет журнал: она добавляет класс события и точку реакции.

Прагматическая составляющая. Получены воспроизводимый стенд публикации, недельные журналы двух подсистем, набор сигнатур Snort и список из четырёх внешних адресов для ACL. Практические шаги: ключи вместо пароля, запрет `root`, ограничение источников, порог отказов и перевод срабатываний IDS в правило межсетевого экрана.

СПИСОК ИСПОЛЬЗОВАННЫХ ИСТОЧНИКОВ

- [1] RFC 4252. The Secure Shell (SSH) Authentication Protocol [Электронный ресурс]. — Режим доступа: <https://www.rfc-editor.org/rfc/rfc4252>. — Дата доступа: 10.09.2026.
- [2] RFC 5737. IPv4 Address Blocks Reserved for Documentation [Электронный ресурс]. — Режим доступа: <https://www.rfc-editor.org/rfc/rfc5737>. — Дата доступа: 10.09.2026.
- [3] Apache HTTP Server. Combined Log Format [Электронный ресурс]. — Режим доступа: <https://httpd.apache.org/docs/2.4/logs.html>. — Дата доступа: 10.09.2026.
- [4] Snort. Official documentation [Электронный ресурс]. — Режим доступа: <https://www.snort.org/>. — Дата доступа: 10.09.2026.
- [5] Suricata. Open source IDS/IPS [Электронный ресурс]. — Режим доступа: <https://suricata.io/>. — Дата доступа: 10.09.2026.
- [6] OSSEC. Host-based intrusion detection [Электронный ресурс]. — Режим доступа: <https://www.ossec.net/>. — Дата доступа: 10.09.2026.
- [7] Fail2ban [Электронный ресурс]. — Режим доступа: <https://www.fail2ban.org/>. — Дата доступа: 10.09.2026.